

Ve pensando un escenario:



Planta Potabilizadora de agua



02



Oleoducto



03



Centrifugadora nuclear



¿Pueden parchear un PLC
Productivo de una caldera a 200
grados,
un martes a las 3 de la tarde?

Infra Critica



Industrias



El día que casi envenenan una ciudad por TeamViewer.



Oldsmar, Florida. Ciudad de 15.000 personas.

Una planta de tratamiento de agua. Una HMI con TeamViewer sin MFA.



Tres minutos de un operador atento.

15.000

personas

abastecidas por la planta

100 →
11.100

ppm

soda cáustica · 100× el nivel normal

3 minutos

para reaccionar

el operador revirtió el cambio

¿Cómo entraron? TeamViewer sin MFA · password compartida · Windows 7 sin parches · expuesto a internet.

Cómo un password viejo paró el 45% del combustible de la costa este.



Colonial Pipeline. Ciudad de 15.000 personas.

Una planta de tratamiento de agua. Una HMI con TeamViewer sin MFA.



Un password viejo. 5 días sin combustible.



Houston → Linden

8.800 km

del oleoducto más grande de combustibles refinados de USA.

45%

del combustible de toda la costa este pasa por ese caño.

El equivalente a un único oleoducto que abastezca toda la región pampeana.

100 GB

exfiltrados en 2 horas

5 días

todo parado · pánico, filas, estado de emergencia

USD 4.4M

de rescate pagado en bitcoin

Lección: ni siquiera hace falta atacar OT directamente. Tirando IT, OT cae sola.



La primera arma cibernética de la historia.

200.000

PCs infectadas
mundialmente

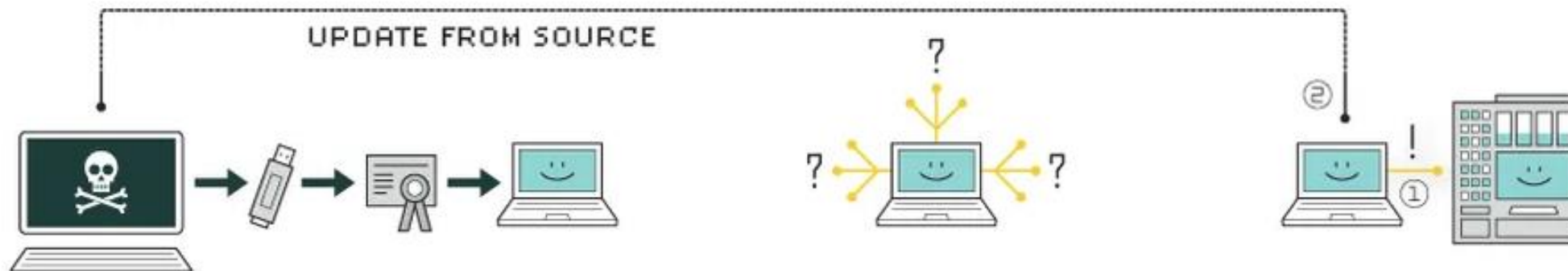
1

sola planta dañada
(Natanz)

1.000

centrifugadoras IR-1
destruidas

Funcionamiento.



Infección:

Stuxnet entra en un sistema a través de una memoria USB y procede a infectar todas las máquinas con Windows mediante un certificado digital que parece proceder de una empresa fiable, el gusano es capaz de eludir los sistemas de detección automática.

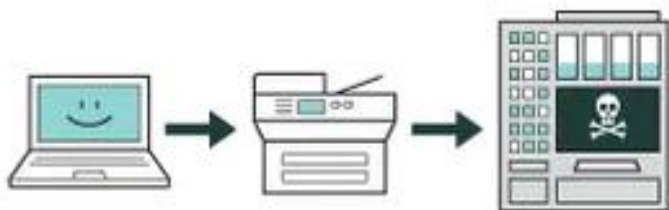
Búsqueda:

A continuación, Stuxnet comprueba si una máquina determinada forma parte del sistema de control industrial fabricado por Siemens. Este sistema se utiliza en Irán para hacer funcionar centrifugadoras de alta velocidad que ayudan a enriquecer combustible nuclear.

Actualización:

Si el sistema no es un objetivo, Stuxnet no hace nada; si lo es, el gusano intenta acceder a Internet y descargar una versión más reciente de sí mismo.

Funcionamiento.



Compromiso:

El gusano compromete entonces los controladores lógicos del sistema objetivo, explotando vulnerabilidades de software de "día cero" que no han sido identificadas por los expertos en seguridad.



Control:

al principio, Stuxnet espía el funcionamiento del sistema objetivo, luego utiliza la información que ha recopilado para tomar el control de las máquinas centrífugas, haciéndolas girar a alta velocidad hasta que fallen.

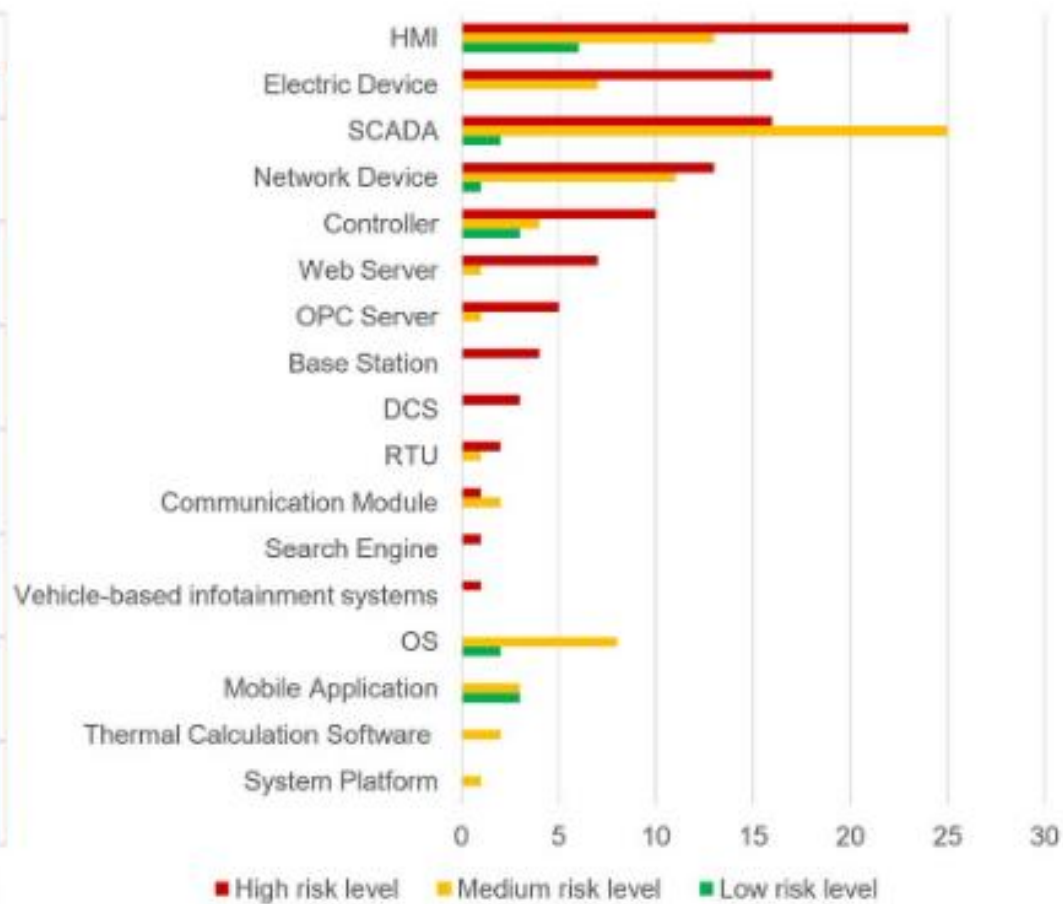
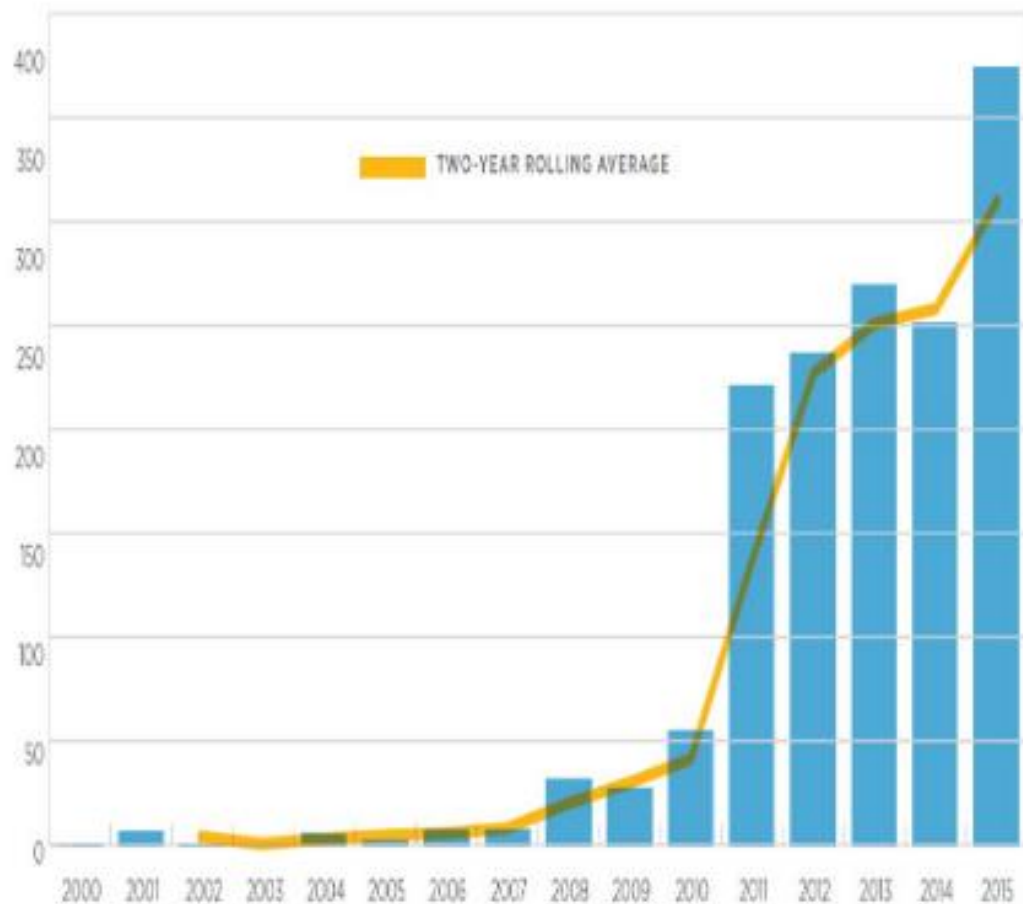


Explotación y destrucción:

Mientras tanto, proporciona información falsa a los controladores externos(HMI), asegurando que no se reconozca el mal funcionamiento hasta que sea demasiado tarde para hacer algo al respecto.



Crece el interés respecto a la seguridad en entornos ICS



En IT la pirámide se invierte.



Menor Importancia



Disponibilidad: El sistema funciona correctamente

Integridad: El sistema funciona como esperamos

Orientado a **Safety**

«Una caldera sin control no es como un servidor que se cae: la caldera explota.»



Cuatro reflejos cambian.



01

Parchear



02

Escanear



03

**Implementar
(EDR / Antivirus)**



04

Reboot

Lo que normalmente hacemos en IT, en OT puede parar (o romper) una planta.



Tu reflejo IT, su reflejo OT.

MUNDO IT

MUNDO OT

01 Parchear	Patch tuesday. Si rompe algo, lo arreglo después.	Ventana cada 4 años. Vendor tiene que validar. 1 min parado = USD 10k.
02 Escanear	Nmap semanal. Descubrimiento de activos.	Un Nmap inocente puede colgar un PLC viejo. Solo monitoreo pasivo.
03 EDR / Antivirus	Más cobertura, mejor. CrowdStrike, SentinelOne en todo.	El EDR consume CPU de la HMI. Sin auto-update. Validado por vendor o nada.
04 Reboot	Lo reinicio a ver qué pasa. El truco más viejo del manual.	Jamás a ciegas. Una válvula puede quedar en estado indefinido.



"Si funciona, no lo toques."

MUNDO IT

3-5 años

vida útil de un servidor

3 años

ciclo de refresh de laptops

Continuo

Patch tuesday, refresh anual

5-7 años

soporte del vendor

MUNDO OT

20-30 años

vida útil de un PLC

15-25 años

vida de una HMI

Cada 4 años

ventana de mantenimiento típica

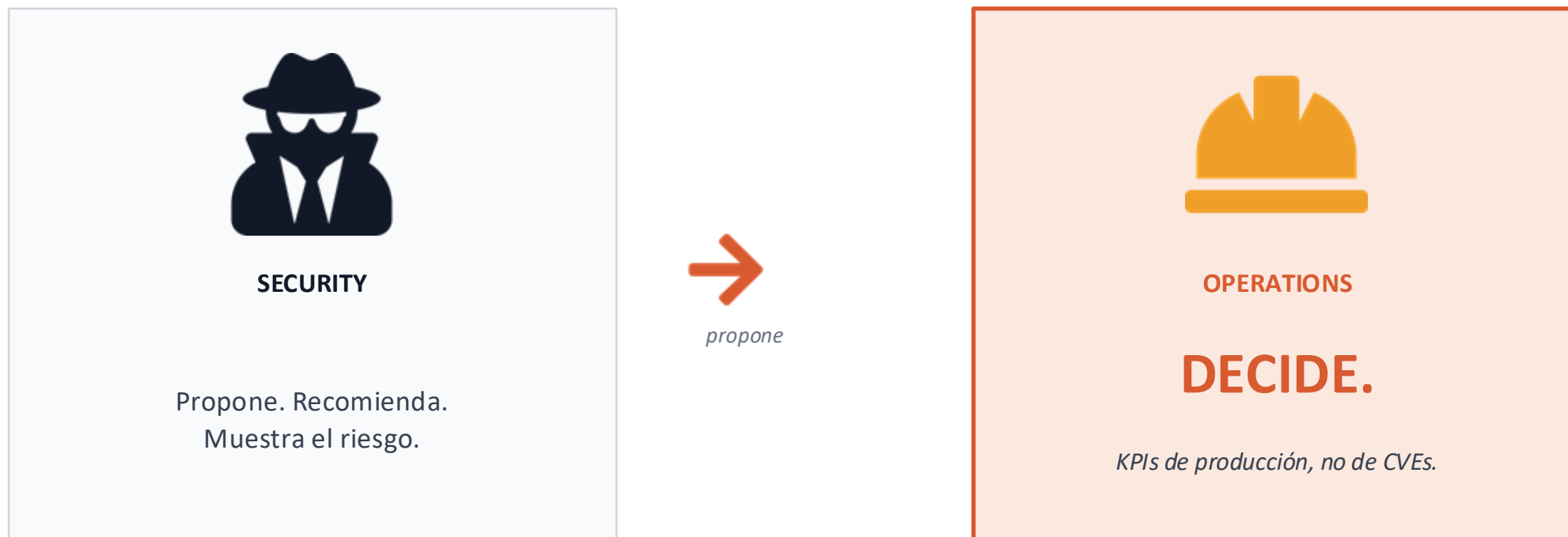
30+ años

soporte del vendor industrial

Tres razones: inversión brutal · lógica certificada · «no lo toques, está andando».



Nosotros Proponemos. El operador decide.



"Esto que querés instalar, ¿me va a parar la línea?"



IT

Se aplican regularmente en los sistemas estándares

Implementado y autogestionados en todos los equipos windows

Equipos centralizados y dedicados, operaciones y procedimientos estándares

Cuentas nominativas

La interrupción del servicio esta bien fuera de los horarios de negocio

Estandar TCP/IP, se heredan la autenticación y cifrado

No hay personas en peligro

Parches de seguridad

AntiVirus

Sistema de Administración

IAM

Disponibilidad

Protocolos

Impacto

OT

Los mismos pueden “romper” el ICS /Sistemas EOL/ Solo en paradas de planta.

Se solía prohibir el uso de antivirus, ya que se perdía el soporte/garantía.

Entornos heterogéneos, muchas herramientas diferentes por utilizar, el soporte del proveedor es obligatorio

Cuentas genéricas, compartidas, sin políticas de contraseñas

Es inaceptable el tiempo de inactividad en operaciones de tiempo real, puede ser muy costoso

Protocolos propietarios sin seguridad incorporada

Posible impacto en persona, medioambiente y maquinaria



En IT proteges datos.

En OT proteges procesos físicos.

**Y los procesos físicos pueden lastiman
personas.**



Hardware industrial: el tour de 10 minutos (o menos).

Para hablar con operations, hay que ponerle cara a cada componente.

PLC

RTU

HMI

SCADA

DCS

Historian

Sensores



Microcontroladores industriales con esteroides.



PLC

Programmable Logic Controller

Lee entradas, ejecuta lógica, escribe salidas.
Cycle time: 10–100 ms. Determinístico, en tiempo real.

MARCAS

Siemens · Allen-Bradley · Schneider · Mitsubishi · Omron



RTU

Remote Terminal Unit

El primo del PLC, diseñado para vivir afuera.
–20 °C.

DÓNDE

Edenor · Edesur · Transener

Sus protocolos (Modbus, DNP3, Profinet) asumen una red confiable. Legado de 40 años.



Si el PLC es el cerebro, la HMI es la cara.



HMI

Human Machine Interface

PC industrial corriendo Windows.

Wonderware · WinCC · FactoryTalk

¿Por qué es objetivo prioritario?

1

Es Windows.

Atacable con técnicas IT clásicas — phishing, lateral movement, exploits conocidos.

2

Da acceso al control.

El operador puede mandar comandos desde acá. Si la comprometen, ellos también.

3

Permite engañar al operador.

Mostrar valores falsos mientras la planta está descontrolada. Eso hizo Stuxnet.

4

Lo demostró Oldsmar.

El atacante movió el mouse de una HMI por TeamViewer. Sin tocar el PLC.



Subiendo un nivel: orquestación.



SCADA

Supervisory Control and Data Acquisition

El dashboard global. Recibe datos de PLCs y RTUs distribuidos geográficamente.

MARCAS

Wonderware · GE iFIX

Edenor ve cientos de subestaciones del AMBA



DCS

Distributed Control System

Concepto similar pero pensado para procesos continuos en una sola planta.

MARCAS

Honeywell Experion · Emerson DeltaV · ABB 800xA

Refinerías, papeleras, plantas químicas



Historian

Time-series database industrial

Guarda cada valor de cada sensor durante años. El Prometheus/InfluxDB de OT.

MARCAS

OSIsoft PI · Wonderware Historian · AspenTech IP.21

Puente natural entre OT e IT



Volvemo al nivel cero. Donde la red toca la realidad.

SENSORES

Miden la realidad física.

Temperatura, presión, flujo, nivel, pH, vibración.

ACTUADORES

Cambian la realidad física.

Válvulas, motores, robots, calentadores, bombas. Lastiman gente.

EL ZOOLOGICO DE PROTOCOLOS OT

Modbus

1979

El telnet de OT.
Simple, omnipresente.
Sin auth, sin encrypt.

Profinet

Siemens

Sobre Ethernet.
Muy común en automotive.
Sin encrypt por default.

EtherNet/IP

Rockwell

Sobre Ethernet.
Common en manufacturing.
Sin encrypt por default.

DNP3

Utilities

Energía y agua.
Versión "Secure Auth":
poco implementada.

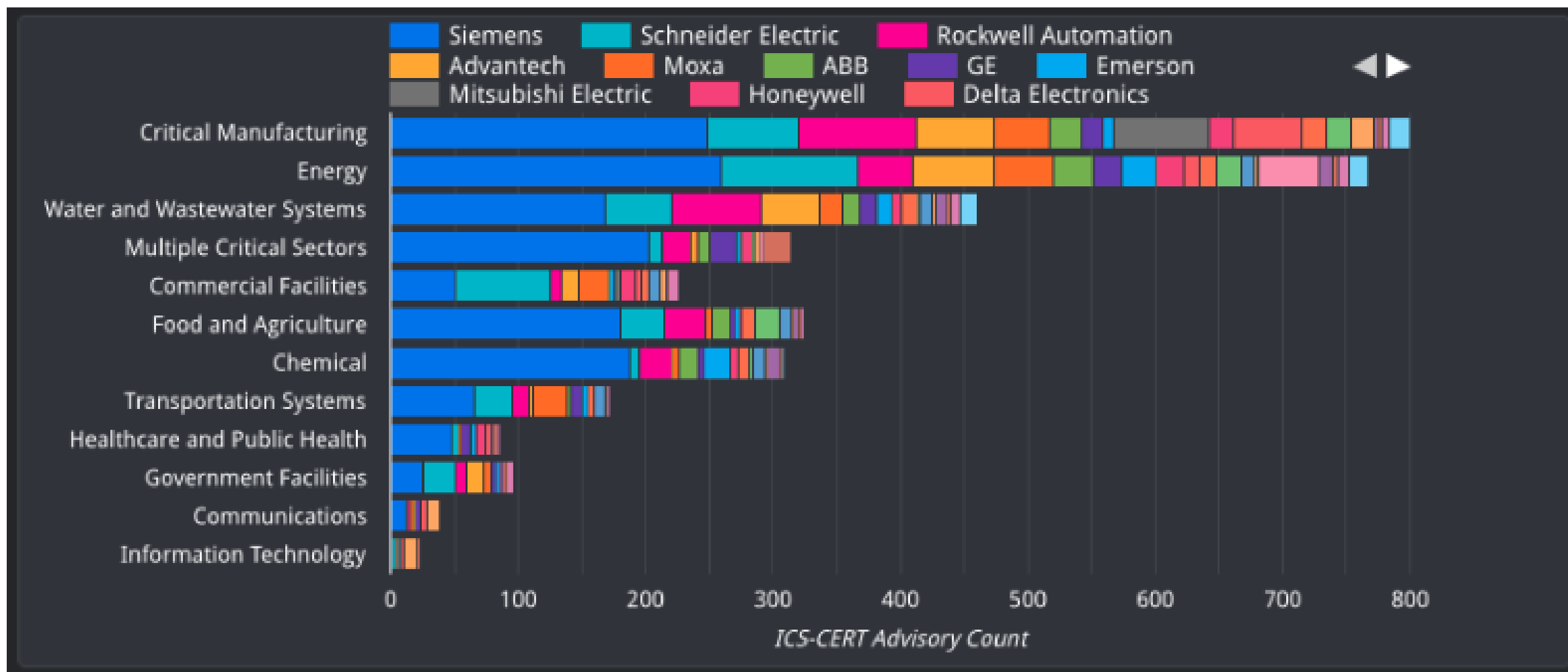
OPC UA

El bueno

El REST de OT.
Certificados X.509.
TLS · auth nativa.

Principales Players.

MARCA	FAMILIAS DE PLC (EJEMPLOS)	SOFTWARE DE PROGRAMACIÓN	DESTACADOS	PROTOCOLOS COMUNES
SIEMENS	S7-1200, S7-1500, ET 200SP, S7-300/400, LOGO! 8	TIA Portal	Plataforma escalable, seguridad integrada, diagnóstico avanzado y gran soporte para movimiento y drives.	PROFINET, PROFIBUS, Modbus TCP, OPC UA, EtherNet/IP, AS-i, IO-Link
 Allen-Bradley	ControlLogix, CompactLogix, Micro800, MicroLogix	Studio 5000 (Logix Designer)	Plataforma robusta, muy usada en Norteamérica, excelente integración dentro del ecosistema Rockwell.	EtherNet/IP, ControlNet, DeviceNet, Modbus TCP, DF1, OPC UA, DH+
 MITSUBISHI ELECTRIC	iQ-R, iQ-F, FX5U, L Series	GX Works3 / GX Works2	Alto desempeño, procesamiento rápido, control de movimiento preciso y opciones compactas.	CC-Link IE, CC-Link, Ethernet, Modbus TCP, RS-232/485, MELSOFT
OMRON	NX Series, NJ Series, CP1L / CP1E, CJ2M	Sysmac Studio (CX-Programmer para legacy)	Automatización integrada, funciones de seguridad y robótica, configuración simple y buena visualización.	EtherNet/IP, EtherCAT, Modbus TCP, OPC UA, FINS, Host Link, RS-232/485
 Schneider Electric	Modicon M221, M241, M251, M580, Quantum	EcoStruxure Machine Expert (Unity Pro para legacy)	Arquitectura abierta, gestión de energía, alta conectividad y flexibilidad para sistemas de gran porte.	Modbus TCP/RTU, EtherNet/IP, PROFINET, OPC UA, CANopen, EtherCAT
ABB	AC500, AC500-eCo, PM5xx, S500	Automation Builder (IEC 61131-3)	Diseño modular y confiable, buen rendimiento en ambientes exigentes, seguridad integrada y control de movimiento.	EtherNet/IP, PROFINET, Modbus TCP/RTU, CANopen, OPC UA, PROFIBUS
 DELTA	AH Series, DVP Series, AS Series	ISPSoft / WPLSoft	Opción competitiva para automatización básica, tareas rápidas y expansión de I/O con bajo consumo.	Modbus TCP/RTU, EtherNet/IP, CANopen, DMCNET, OPC UA, RS-232/485
BECKHOFF	CX20xx (Embedded), CX50xx (Control Cabinet), TwinCAT PLC	TwinCAT 3	Control basado en PC, muy alto rendimiento, interfaces abiertas, automatización avanzada e integración IoT.	EtherCAT (nativo), PROFINET, EtherNet/IP, Modbus TCP, OPC UA, ADS, TCP/IP



Source: <https://www.icsadvisoryproject.com/>



Tres mapas, tres usos.



el mapa

Mapea DÓNDE vive cada cosa.



el manual

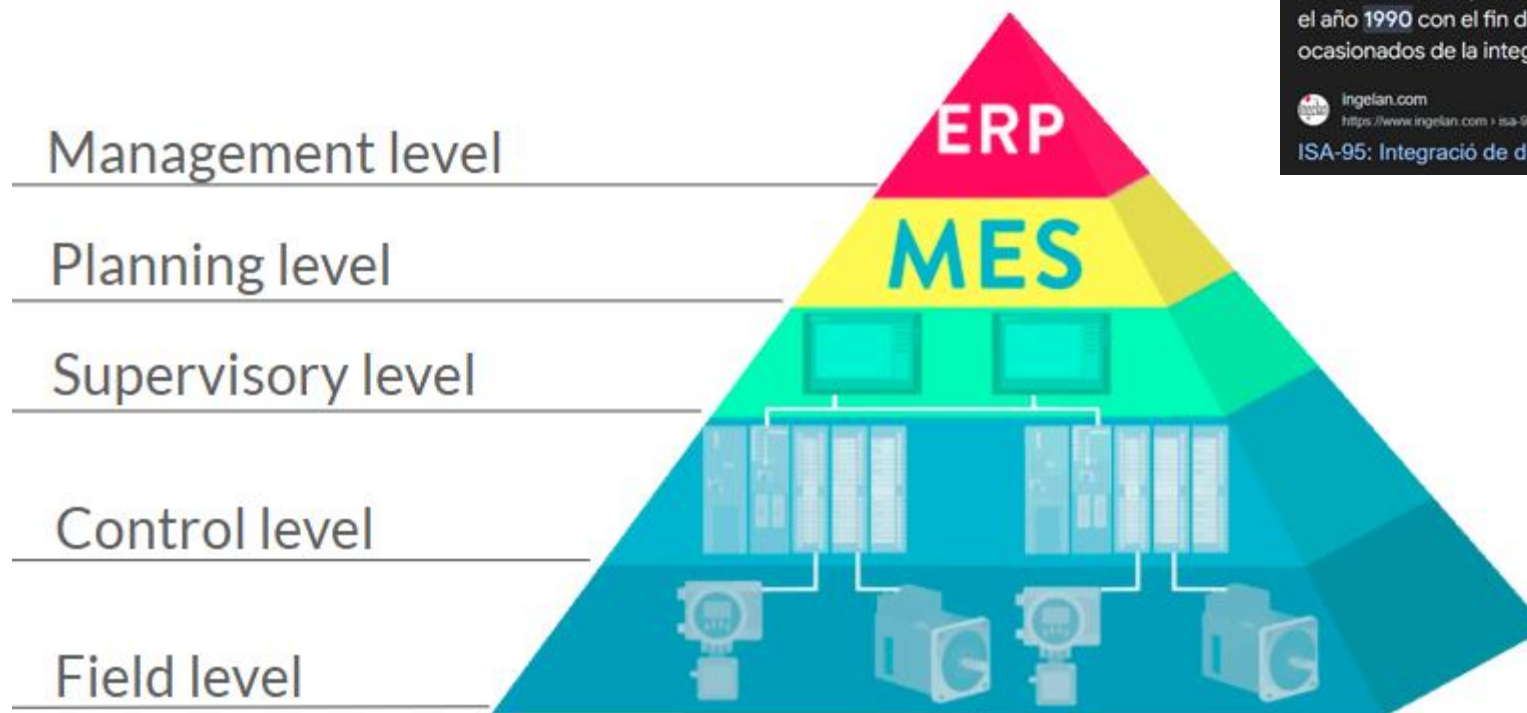
Define que tener en cuenta a la hora de protegerla. NO EL COMO.



el idioma

Habla con IT y el directorio.

El lenguaje común del mundo OT.



ISA-95: Integración de los sistemas de control empresarial

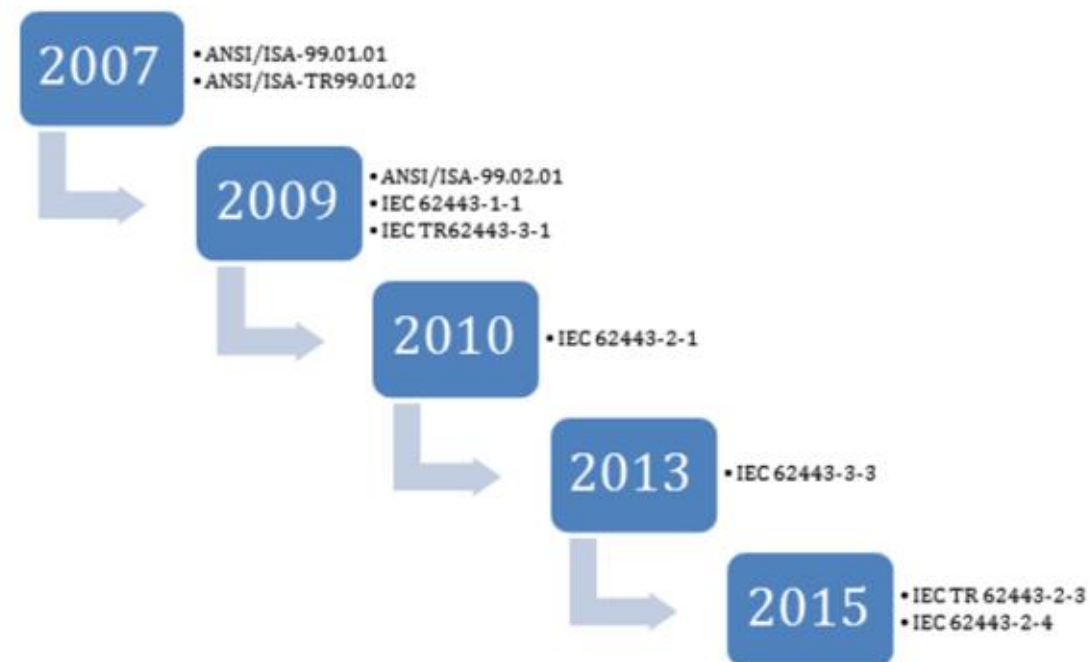
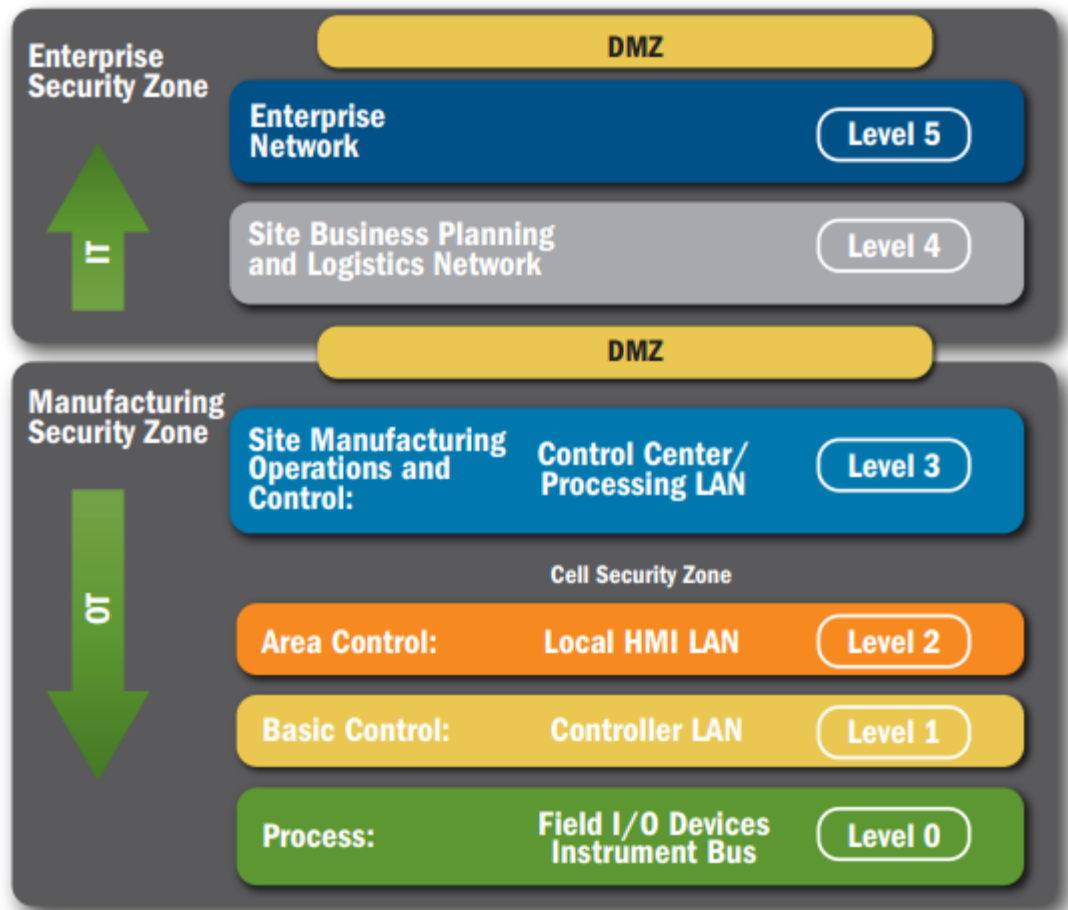
Fue desarrollada por la ISA (Sociedad internacional de automatizació) en el año 1990 con el fin de reducir los costes, los riesgos y los errores ocasionados de la integración de los sistemas de control industriales.

 [ingelan.com](https://www.ingelan.com)
<https://www.ingelan.com> + isa-95

ISA-95: Integració de dispositius ICS - Ingelan

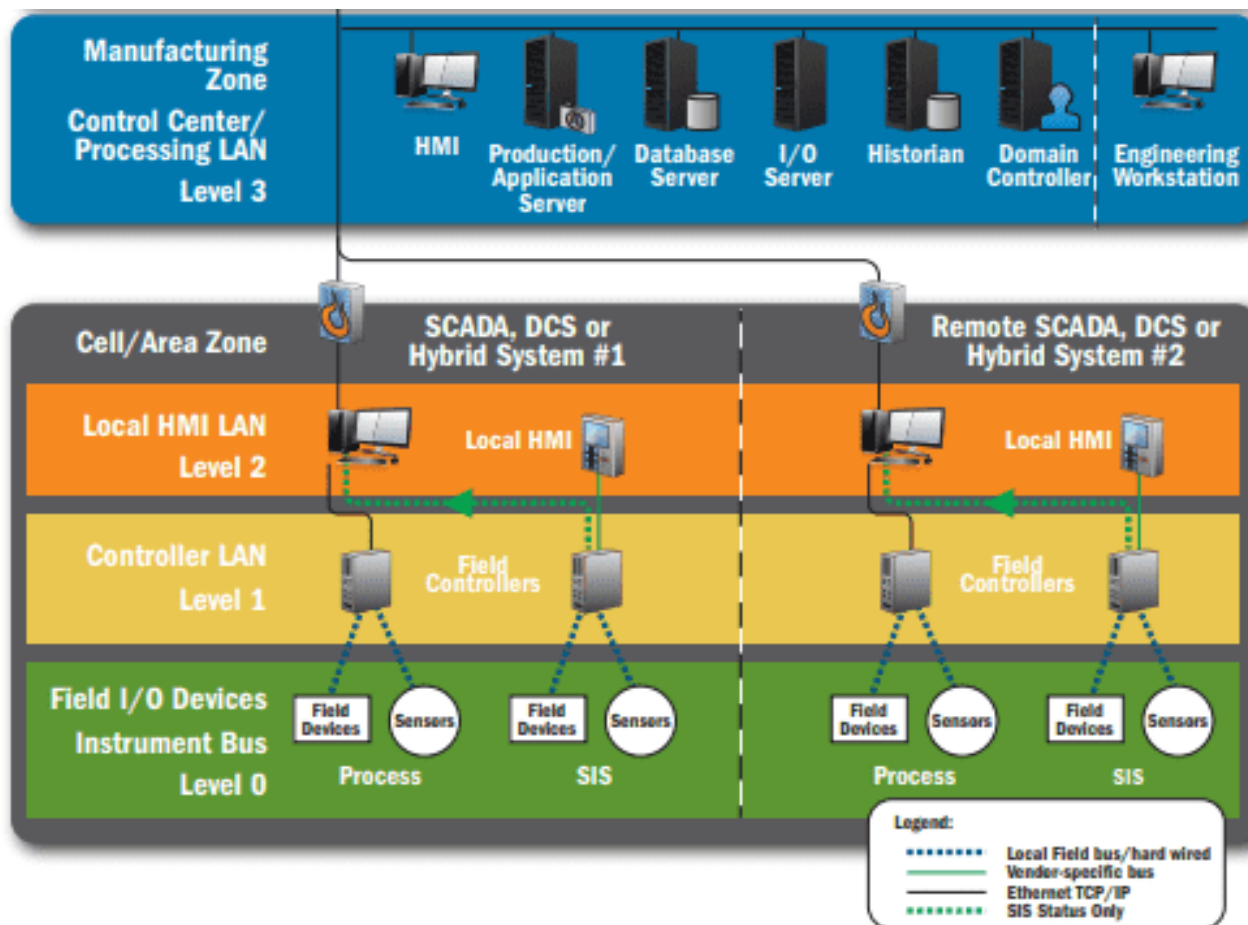
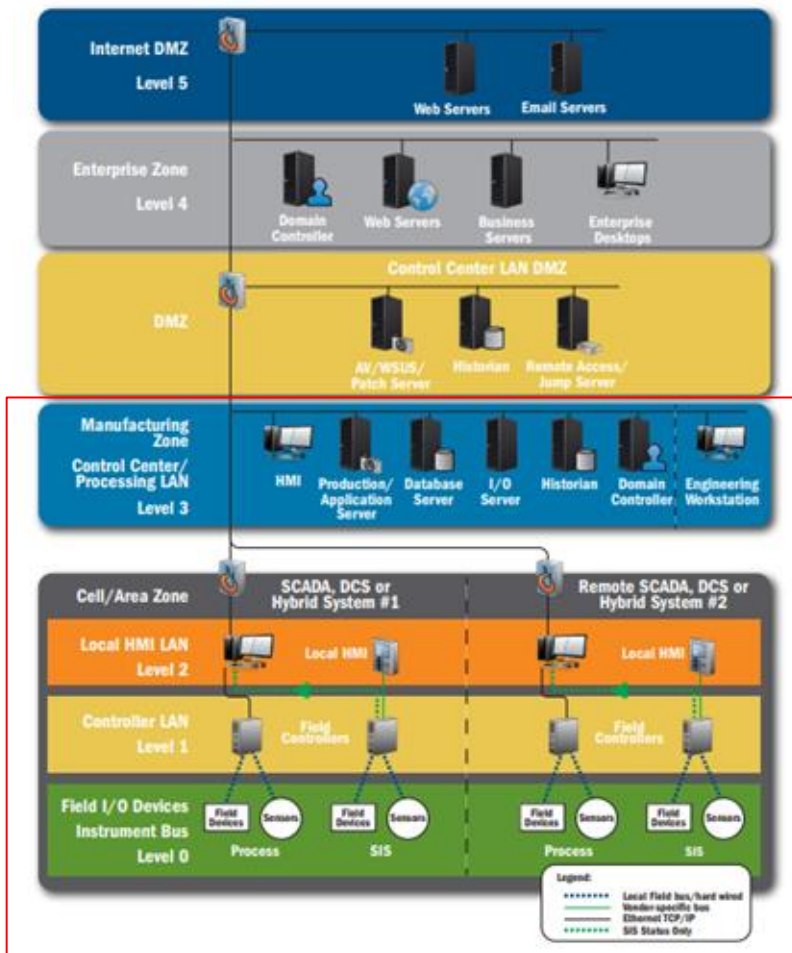
Los sistemas ERP (Planificación de Recursos Empresariales) y MES (Sistema de Ejecución de Manufactura) son herramientas complementarias para la gestión industrial.

El lenguaje común del mundo OT.

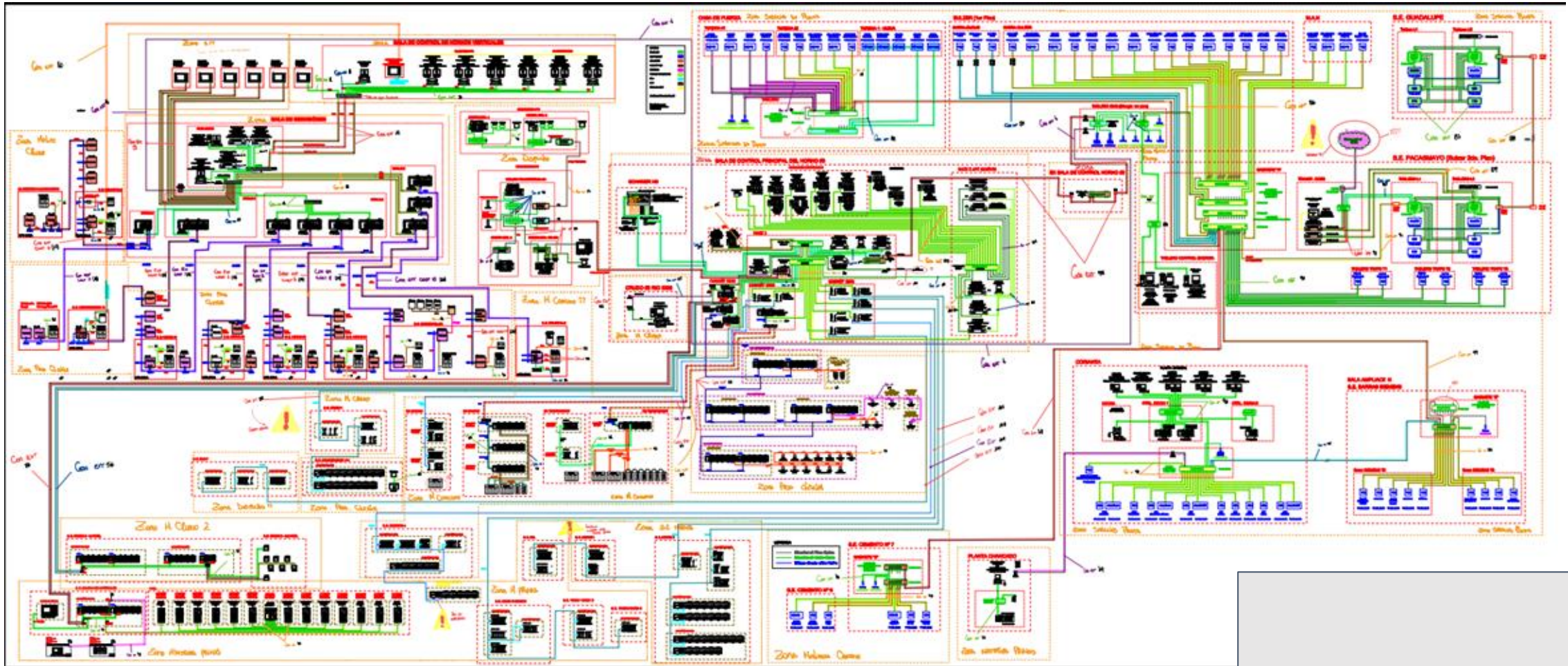


-Publicaciones ISA99 e IEC 62443-

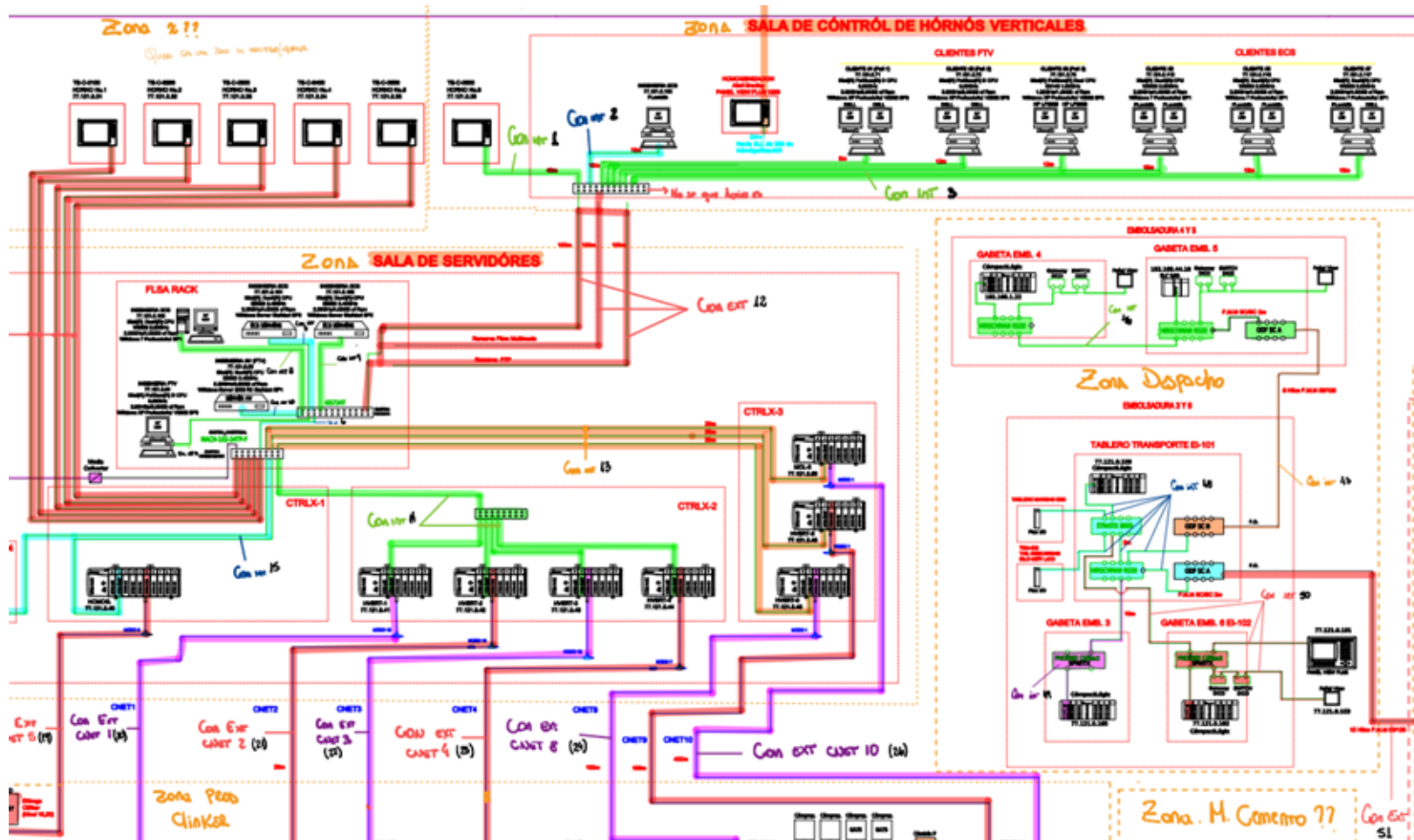
El lenguaje común del mundo OT.



El lenguaje común del mundo OT?????????.



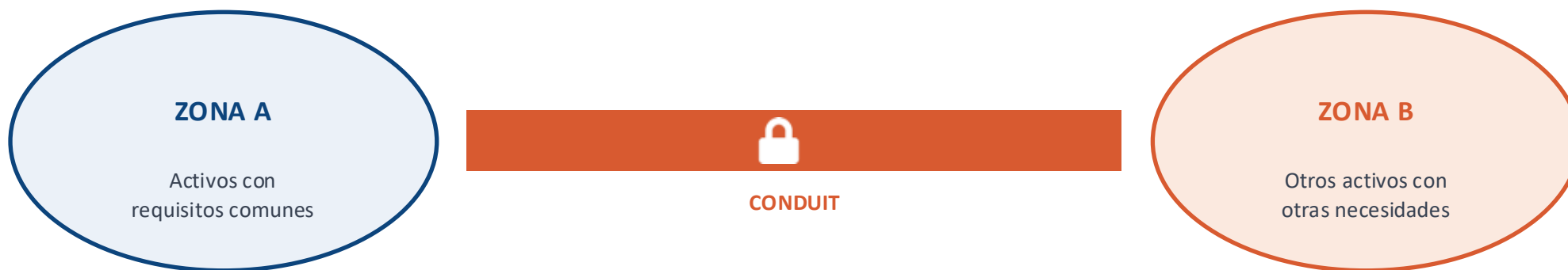
El lenguaje común del mundo OT??????????.





Zonas, conduits y niveles de seguridad.

Canal seguro entre zonas. Encriptado, monitoreado, controlado.



SECURITY LEVELS — ¿CONTRA QUÉ ATACANTE?

SL 1

Violaciones casuales
o no intencionales

SL 2

Atacantes intencionales
con bajos recursos

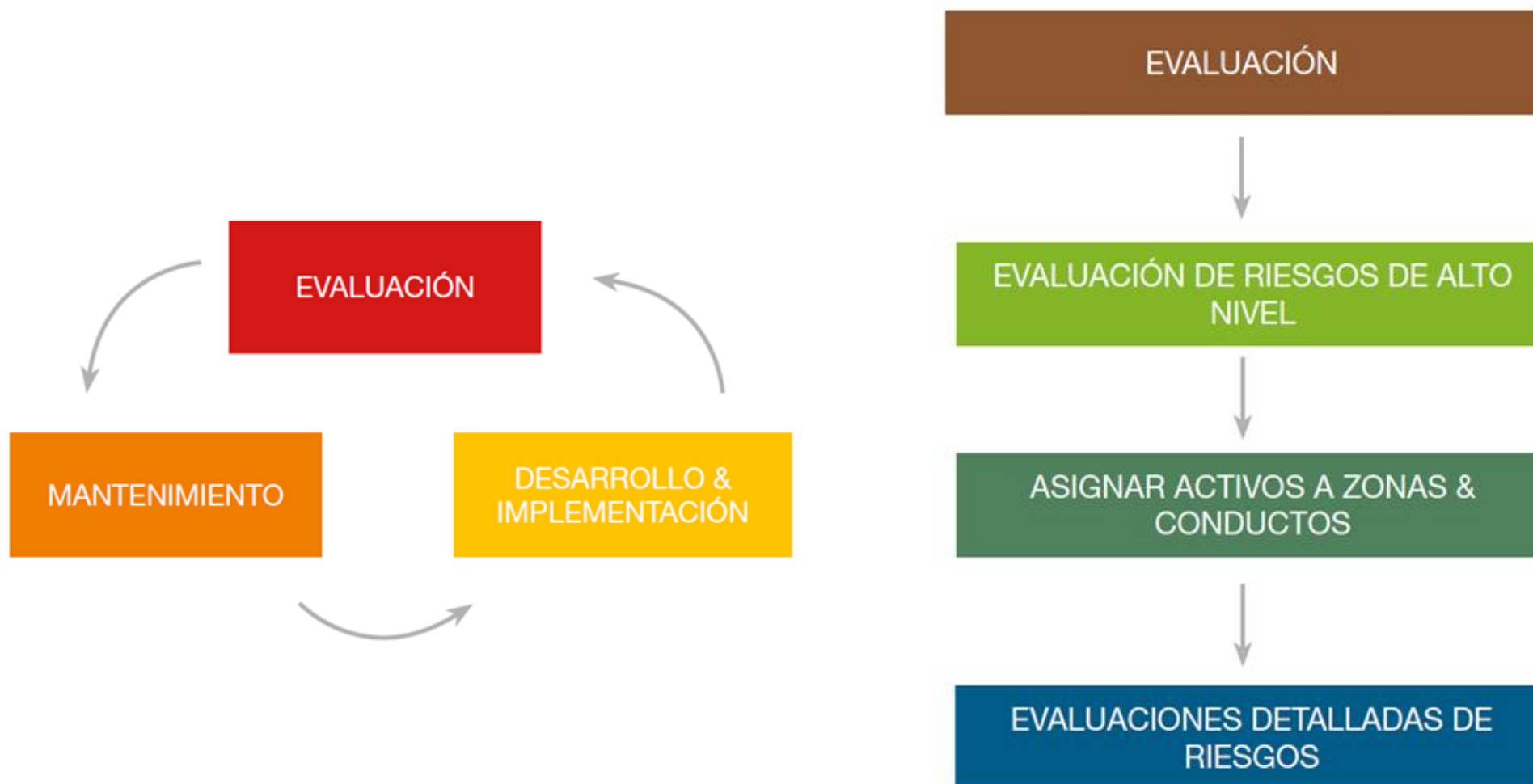
SL 3

Atacantes intencionales
con recursos moderados

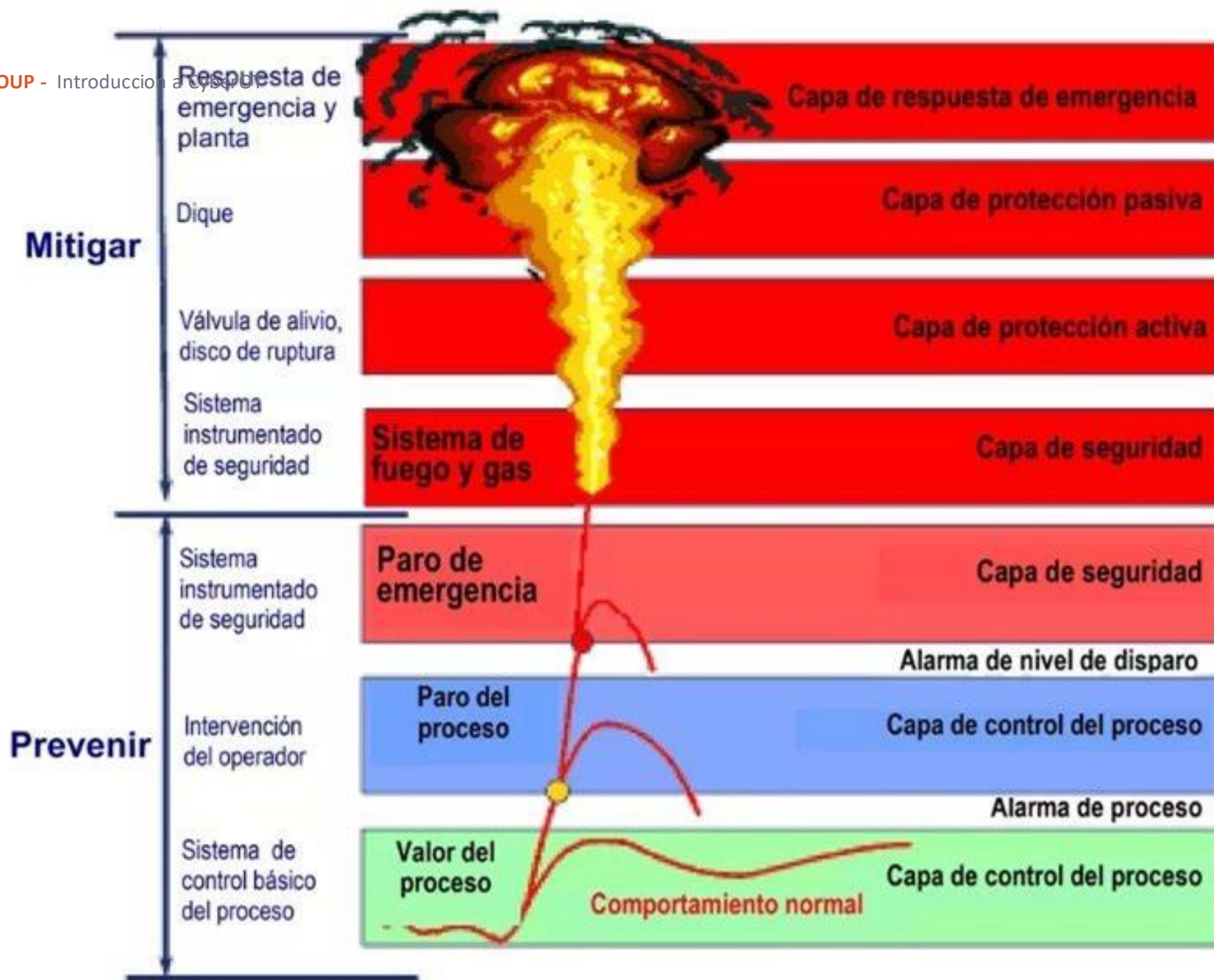
SL 4

Estado-nación

Zonas, conduits y niveles de seguridad.



Safety.





El idioma común con IT.

GOVERN

Políticas, riesgos, supply chain · CSF 2.0

IDENTIFY

Qué tengo, qué riesgo tiene
cada cosa

PROTECT

Controles preventivos

DETECT

Monitoreo, alertas

RESPOND

Qué hago cuando pasa algo

RECOVER

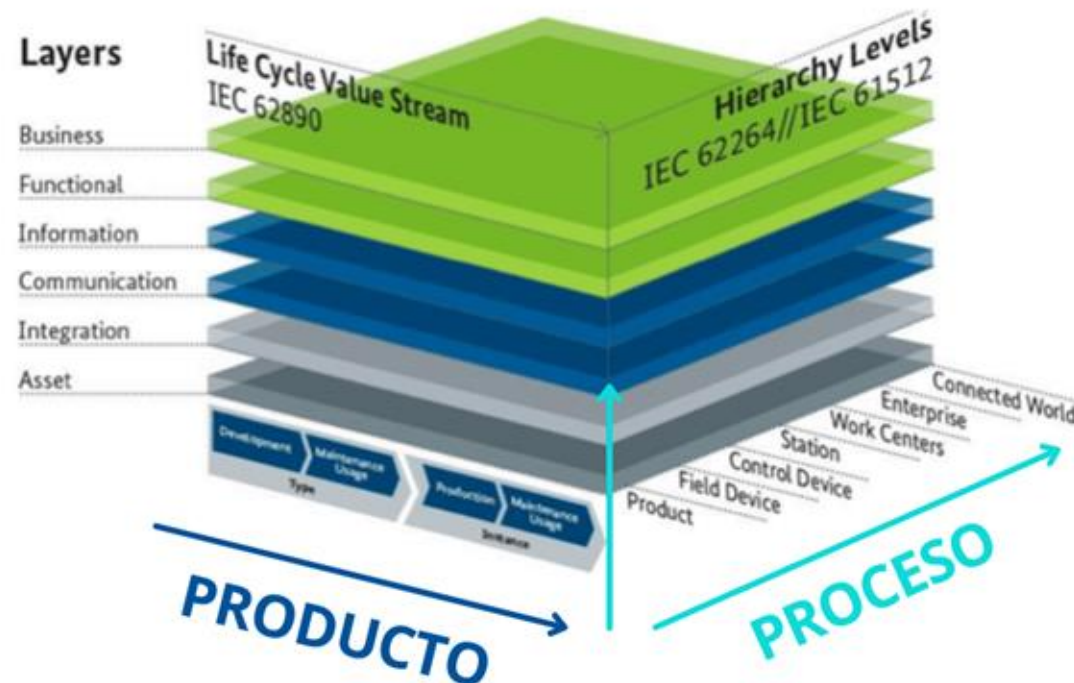
Cómo vuelvo a operar

NIST SP 800-82 = la guía de aplicación específica al mundo industrial.

El idioma común con IT.



Arquitectura RAMI 4.0



DIN SPEC 91345, también conocida como RAMI 4.0 (Reference Architectural Model for Industry 4.0), es una especificación técnica alemana que define un marco de referencia para la digitalización industrial. Publicada por DIN (Deutsches Institut für Normung) en 2016

El idioma común con IT.

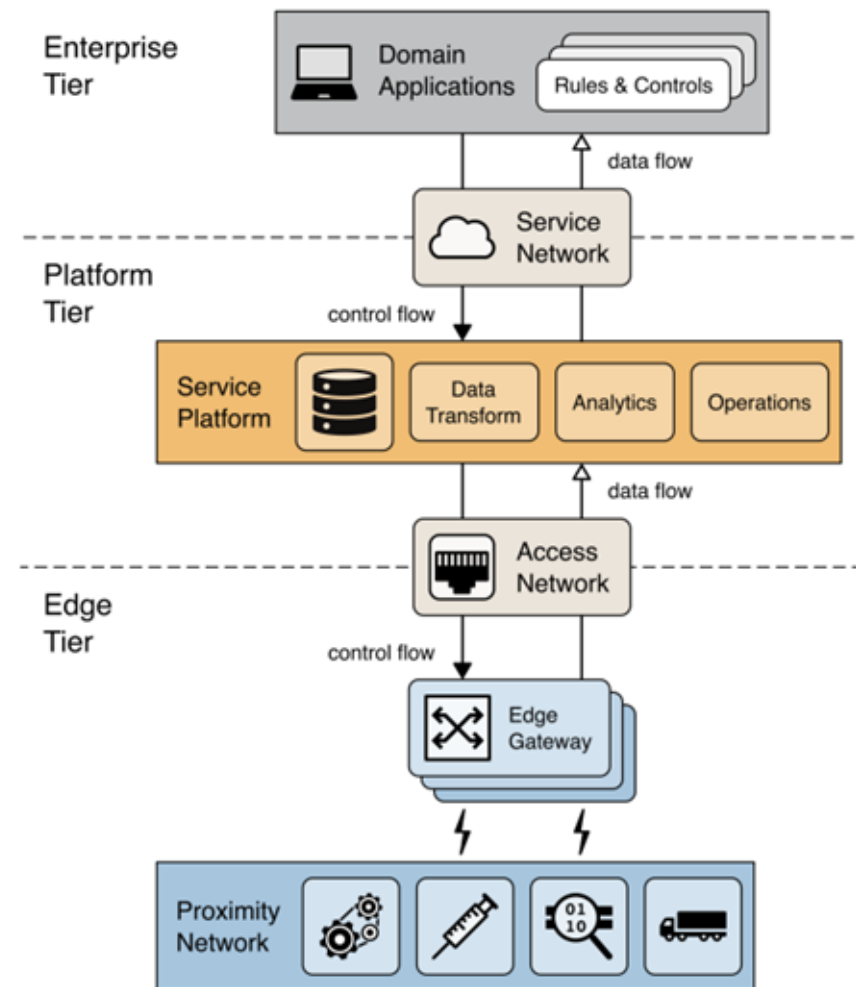
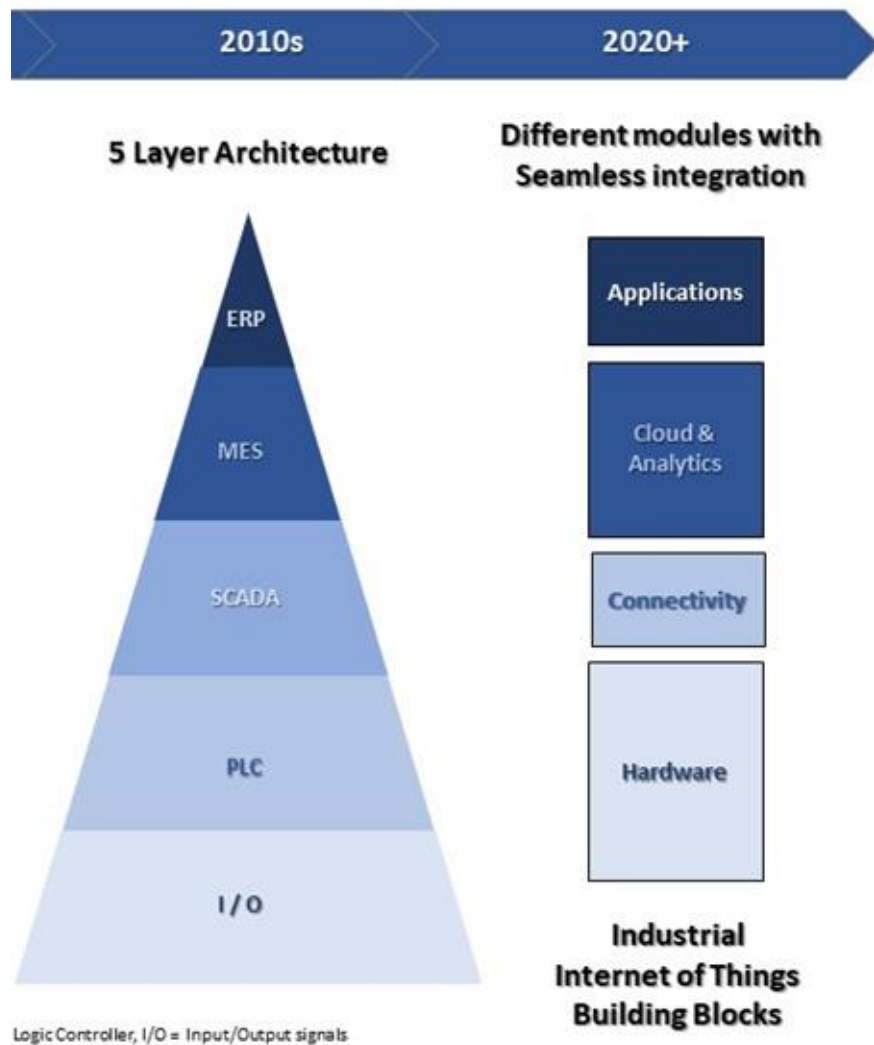
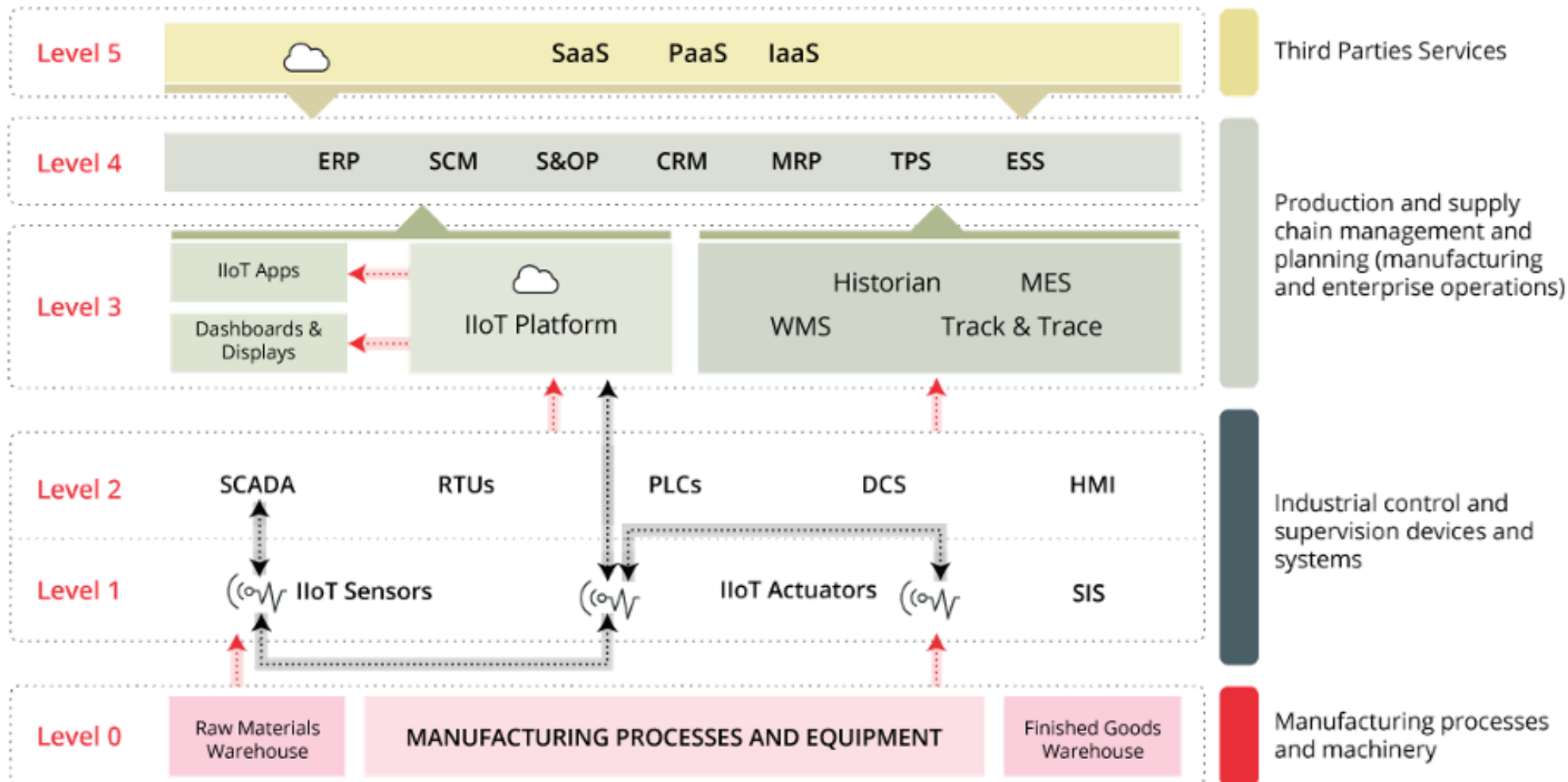


Fig. 12. A three-tiered IIoT system architecture

El idioma común con IT.





De Tarea.



International Society of Automation

[Standards](#) [Certification](#) [Training](#) [Membership](#) [Events](#) [Publications](#) [News](#) [About](#)



News and Press Releases / ISA Announces Publication of New Standard for SCADA Systems

ISA Announces Publication of New Standard for SCADA Systems

February 24, 2026 | Durham, N.C.

The ISA-112 Part 1 standard provides a framework for modernizing supervisory control and data acquisition systems and making them easier to design, build, operate and maintain.

The [International Society of Automation](#) (ISA) — the leading professional society for automation — has announced the publication of **ANSI/ISA-112.00.01-2025, SCADA Systems – Part 1: SCADA Lifecycle, Diagrams and Terminology**, which is now available for sale on www.isa.org and is accessible to ISA members as a membership benefit.

Supervisory control and data acquisition (SCADA) is an automated control system architecture commonly implemented in industrial, utility and manufacturing environments. The ISA-112 Part 1 standard provides a vendor-neutral and technology-independent framework for the long-term management of SCADA systems and execution of SCADA modernization projects, offering a high-level overview of the SCADA lifecycle as well as diagrams and terminology. ISA-112 Part 1 applies to a wide variety of industries, including municipal water/wastewater facilities, oil/gas infrastructure, pipelines, dam/irrigation systems, electricity transmission/distribution, railways, highways, bridges/tunnels, airports, civil infrastructure, manufacturing, mining, defense and remote monitoring. Additional parts of ISA-112 addressing SCADA lifecycle review processes and SCADA architectures are also planned for release.



AWS para OT:

Necesidades Detectadas.

Análisis proactivo de Imágenes En tiempo real.

Soluciona:

- Relevamiento de Activos en Campo
- Detección de fallas automáticas de forma preventiva.
- Seguimiento de tareas y mejoras predictivas al plan de mantenimiento



Acceso Remoto Seguro SRA.

Soluciona:

- Quién se conecta
- Por qué se conecta
- Desde dónde se conecta
- A qué puede acceder
- Qué puede hacer
- Durante cuánto tiempo
- Quién aprobó el acceso
- Genera evidencia



Monitoreo del estado real En Campo.

Soluciona:

- Verificación física fuera del SCADA
- Alertas sin tocar la red OT
- Evidencia operativa para responder

CONTRAS: Requiere Hard IIOT





AWS para OT:

arquitectura de referencia.

01

Planta on-prem

02

Edge

03

AWS Cloud

Security Best Practices for Manufacturing OT

May 20, 2021



Amazon Web Services

Security Best Practices for Manufacturing OT



Figure 3 — Data to insights

Extracting, structuring, and ingesting data from OT resources to the cloud is the first step to enabling data analysis. AWS has a variety of analytics services in the cloud for processing, analyzing, and generating insights, but the ingestion stage requires hybrid components and interaction with OT resources. Following are some of the key AWS services to enable data ingestion from an OT environment (levels 1-3) to the cloud. Refer to this [Manufacturing on AWS](#) reference architecture diagram for visual representation.

- [AWS IoT Core](#) — Ingest data from the IoT device via [MQTT](#).
- [AWS IoT Greengrass](#) — Ingest data from legacy and IoT devices via MQTT, or various inbuilt / custom connectors and [AWS Lambda](#) functions.
- [AWS IoT SiteWise](#) — Collect, organize, and analyze machine data using [OPC UA](#), [EtherNet / IP](#), [Modbus](#), MQTT, or directly via API calls.
- [Amazon Kinesis](#) — Ingesting streaming data.
- [Amazon CloudWatch](#) — Ingest logs and infrastructure metrics.
- [AWS Data Sync](#) — Ingest and sync on-premises file data to [Amazon Simple Storage Service](#) (Amazon S3).
- [AWS Storage Gateway](#) — Serves as a local file server to ingest data to Amazon S3.
- [AWS Transfer for SFTP](#) — Server as a cloud FTP server to ingest files to Amazon S3.
- [Database Migration Service](#) — Migrate or sync on-premises databases to the cloud.

Apart from AWS services, third-party integrations and services are also available for data ingestion, providing customers a wide portfolio of options to bring their manufacturing data to the cloud.



9



¿Por qué no llevar todo a la nube?



EDGE

Control y procesamiento
sensible al tiempo.



CLOUD

Analítica, agregación
long-term.



Latencia

PLC necesita decisiones en ms.
130 ms a us-east-1: inviable.



Disponibilidad

Sin internet, la planta
sigue produciendo.



Volumen

Terabytes/día.
Caro, lento, la mayoría no lo usás.



Tres opciones de AWS en el sitio.



AWS IoT Greengrass

Software en device industrial

Lambda y Docker corriendo localmente, sincroniza con la nube cuando hay link.

PARA SEGURIDAD

Auth con X.509 · HSM · Device Defender



AWS Snowball Edge

Appliance ruggedizado

Mini AWS region en una caja. EC2 local en sitios con conectividad limitada.

PARA SEGURIDAD

Mina en Catamarca · plataforma offshore Tierra del Fuego



AWS Outposts

Rack AWS on-prem

Mismas APIs y servicios que cloud, corriendo en tu datacenter.

PARA SEGURIDAD

Plantas grandes · multi-tenant · consistencia operativa



De la planta a S3, paso a paso.



IoT Core

Broker MQTT gestionado

X.509 únicos por device. Topics granulares. Todo TLS por default.

IoT SiteWise

El historian del siglo XXI

Habla OPC UA, Modbus, EtherNet/IP nativamente. Modela jerarquías de activos.

Storage Gateway

Historian on-prem → S3

Extiende almacenamiento a S3. Las apps existentes ven un file share local.

REGLA DE ORO *El flujo va planta → edge → cloud. Nunca al revés sin un componente intermedio controlado.*



Cuatro servicios, mapeados a NIST CSF.



GuardDuty

DETECT

ML threat detection.
CloudTrail, VPC Flow Logs, DNS.



IoT Device Defender

DETECT

Audita config + monitorea
comportamiento de devices.



Security Hub

DETECT + RESPOND

Pane of glass único:
cloud + edge + devices.



KMS + Secrets Mgr

PROTECT

Encriptación at rest +
credenciales rotadas.

MAPEO NIST CSF Identify: Config, Inventory · Protect: IAM, KMS, SecMgr · Detect: GuardDuty, DD, SecHub · Respond: EventBridge+Lambda · Recover: Backup, multi-region



De la planta a AWS, sin abrir puertos.



PLANTA

Site-to-Site VPN

IPsec gestionado · simple para empezar

Direct Connect

Conexión dedicada · sin internet · ancho garantizado

IoT Secure Tunneling

Sesión bidireccional sin abrir puertos inbound



AWS



AWS Systems Manager · Session Manager

Olvidate de bastion hosts, SSH keys, RDP expuesto.

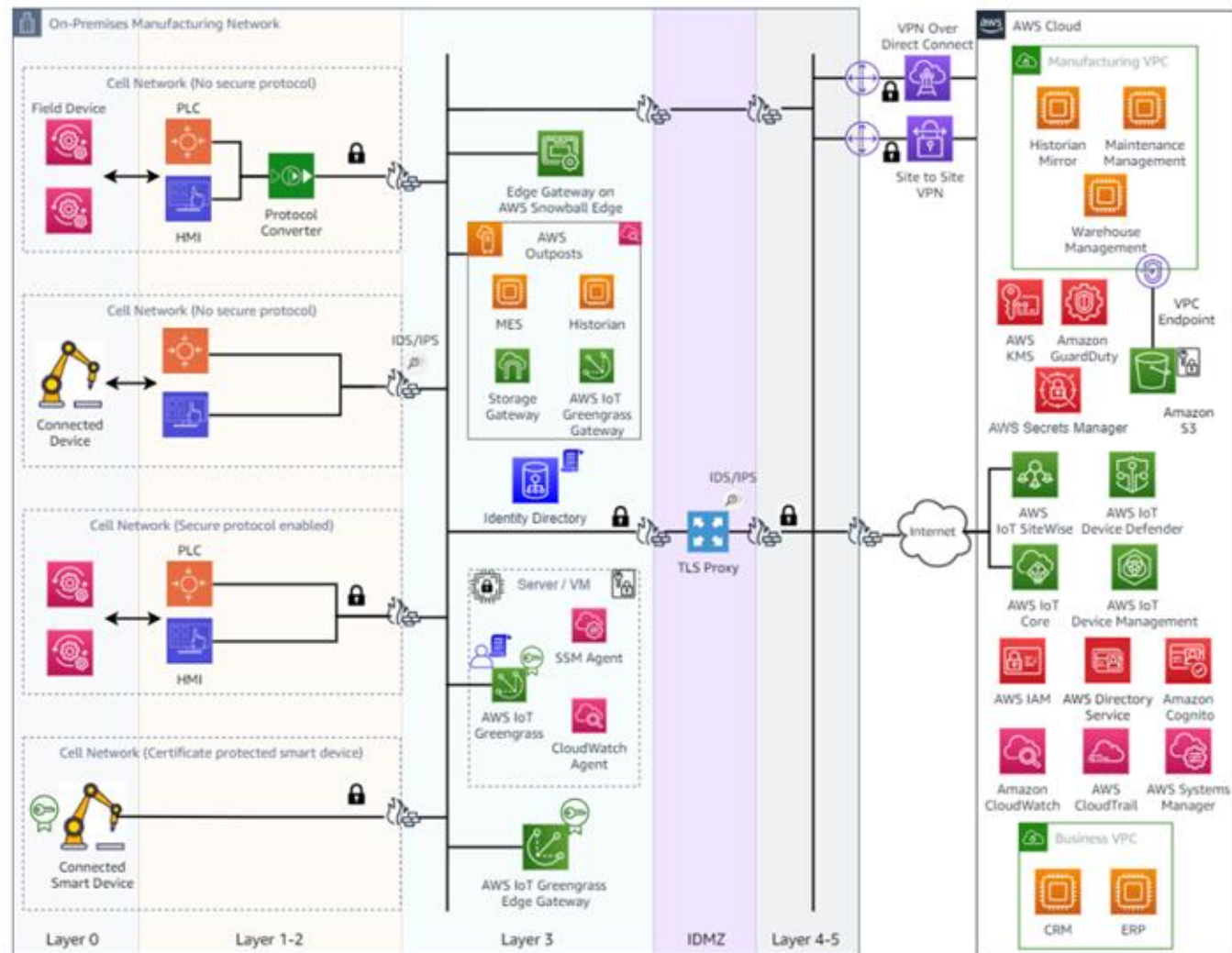
Acceso shell auditado, autenticado con IAM, sin abrir puertos. Es lo que faltaba en Oldsmar.



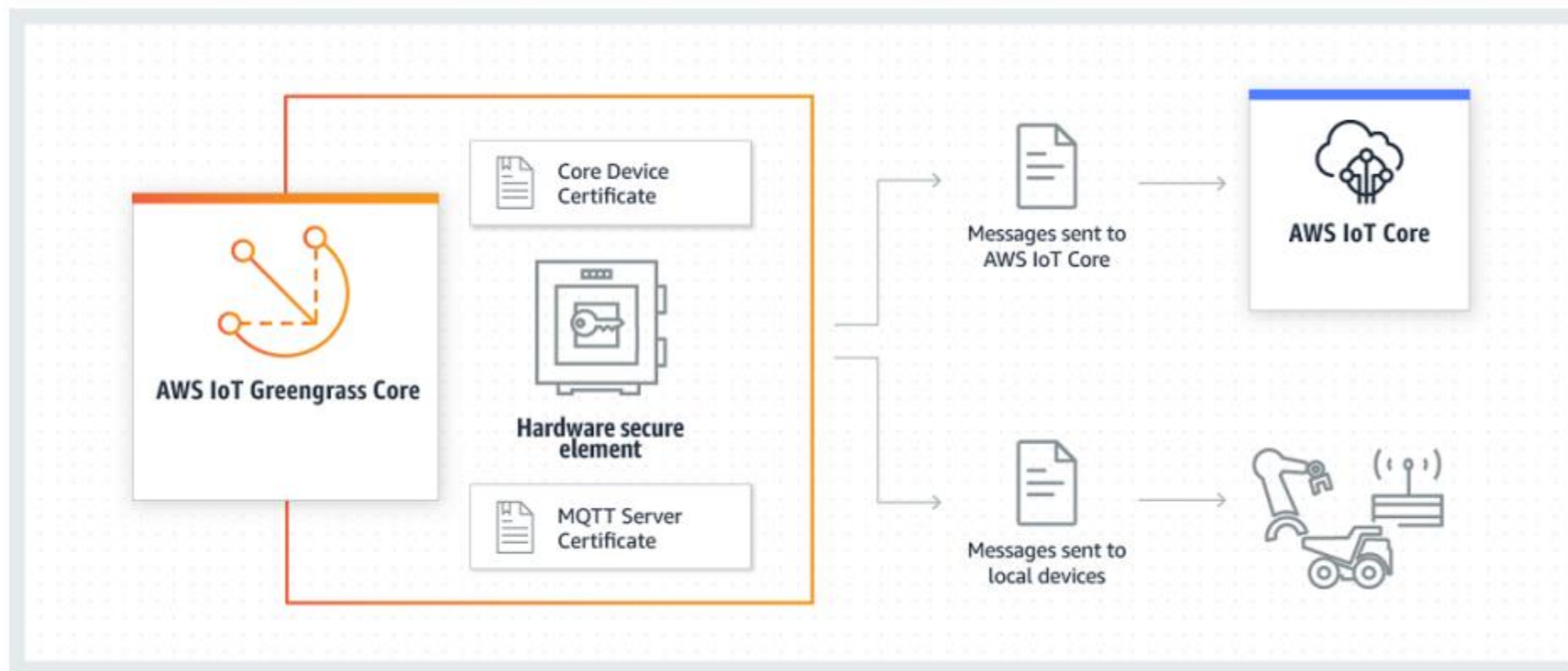
El modelo se vuelve de tres capas.

AWS CLOUD <i>Capa 3</i>	Infra, servicios gestionados, certificaciones	AWS responsable de infra · cliente de su config
EDGE Y CONEXIÓN <i>Capa 2</i>	Greengrass, Outposts, Snowball Edge	Compartido cliente + AWS
PLANTA FÍSICA <i>Capa 1</i>	Hardware OT, redes industriales, operadores, procesos	100% del cliente · AWS no llega acá

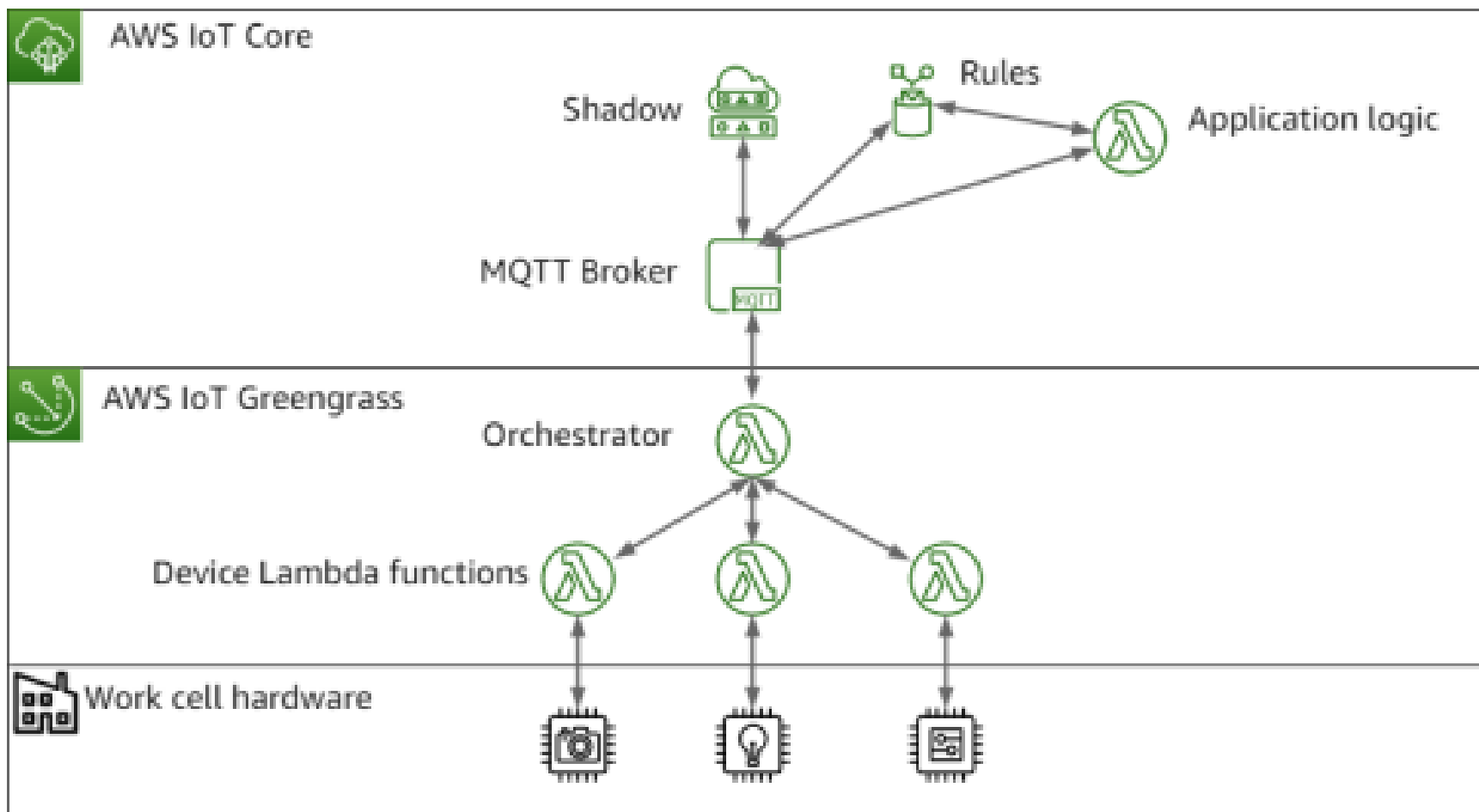
El modelo se vuelve de tres capas.



En Campo.



En Campo.





Compliance regulatorio en cloud: posible y a veces más fácil gap contra NERC.

Requisito	Qué pide	Servicios AWS
CIP-002	Categorización de activos críticos del Bulk Electric System (BES).	AWS Config · Resource Tags · Systems Manager Inventory
CIP-005	Perímetros electrónicos de seguridad (ESP) y control de acceso.	Security Groups · NACLs · Direct Connect · IoT Secure Tunneling
CIP-007	Gestión de seguridad de sistemas: parches, malware, accesos.	Patch Manager · Inspector · IAM · Session Manager
CIP-011	Protección de información BES Cyber System.	KMS · S3 encryption · Macie · Secrets Manager

AWS publica guías similares para IEC 62443, ISO 27001 y otros frameworks.



¿Qué hago el lunes?

SI YA TRABAJÁS CON OT

1 Hagan inventario.

¿Cuántos PLCs? ¿Qué firmware? Sin inventario, no se protege nada. SSM Inventory + Zeek pasivo es buen inicio.

2 Miren la IDMZ.

¿Existe? ¿Está bien definida? Si está mal, todo lo demás es decoración.

3 MFA en accesos remotos.

Revisen TODO acceso remoto. Sin MFA, es la próxima Oldsmar. Reemplacen TeamViewer por Session Manager.

SI QUERÉS METERTE EN OT

4 Aprendé a leer Purdue.

Si podés ubicar un componente en su nivel, ya tenés conversación con un ingeniero OT.

5 Visitá una planta.

Hablá con operadores. Preguntales qué los frustra de IT. Esa empatía vale más que cualquier curso.

6 Pensá como integrador.

OT no necesita más alarmas. Necesita arquitecturas seguras por diseño. Esa es la oportunidad.



Para profundizar después de hoy.



DOCUMENTACIÓN AWS

- Security Best Practices for Manufacturing OT
- AWS User Guide to Support Compliance with NERC CIP Standards



CERTIFICACIONES

- GICSP (SANS)
- ISA/IEC 62443 Cybersecurity Specialist
- AWS Certified Security Specialty



LECTURA

- NIST SP 800-82 — guía oficial ICS, gratuita
- Industrial Network Security · Eric Knapp



COMUNIDADES

- SANS ICS · ISA · ISA Argentina
- AWS Security User Group
- Joe Slowik · Robert M. Lee · Lesley Carhart



En IT proteges datos.

En OT proteges procesos físicos.

Y los procesos físicos puede llegar a

.....



.....lastimar personas.

Siempre y cuando fallen los sistemas
Safety

Gracias.



.....lastimar personas.

Siempre y cuando fallen los sistemas
Safety

Gracias.



.....lastimar personas.

Siempre y cuando fallen los sistemas
Safety

Gracias.